



山东大学
SHANDONG UNIVERSITY

网络与大数据安全

1 - Overview

李琨

Email: kunli@sdu.edu.cn

—— 学无止境 气有浩然 ——



课程大纲

信息安全概述

- 基本安全概念

- 密码学初步和实验

基础密码学

- 对称密钥加密和信息机密性

- 消息认证和哈希功能

- 公钥加密

- 数字签名和密钥管理

身份识别安全

- 各种识别方式

- 访问控制原则

- 互联网认证应用

网络安全概述

- 网络环境和安全威胁

- 网络防御方案

区块链技术

- 区块链技术原理与加密货币

- 区块链共识协议

- 区块链智能合约

人工智能安全

- 大模型面临的安全问题

- 基于隐私计算的防御方案



预期学习成果

完成课程后，学生应能够：

- 了解信息安全的基本概念
- 初步了解密码学
- 识别和评估网络环境常见威胁和主要对策
- 掌握区块链技术的原理
- 了解新兴的大模型面临的安全问题

引言

為天下儲人材 為國家圖富強

—— 學无止境 氣有浩然 ——



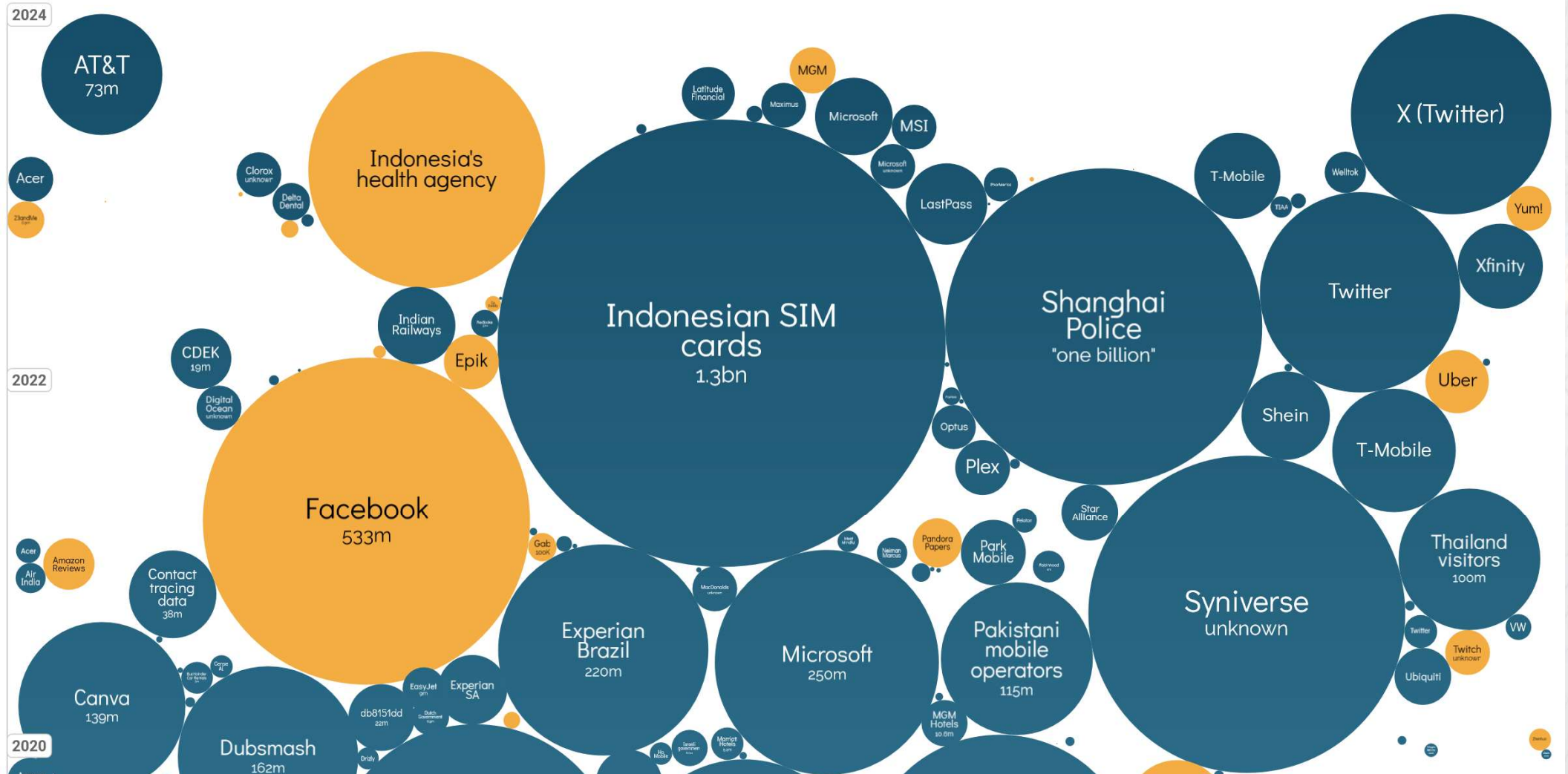
信息安全关乎国计民生和国家安全

- 数据成为生产要素
 - 数据是数字经济的发展动力：大数据、云计算、移动互联网、物联网、人工智能
 - 数据安全保障国家安全：涉及政务商务、军事国防、航空航天、银行证券、医疗卫生等国家重大行业
- 相关法规密集出台，明确要求保护数据的安全和隐私
 - 2016年《国家网络安全战略》
 - 2017年《网络安全法》
 - 2019年《网络安全等级保护基本要求》
 - 2019年《密码法》
 - 2020年《个人信息安全规范》
 - 2021年《数据安全法》



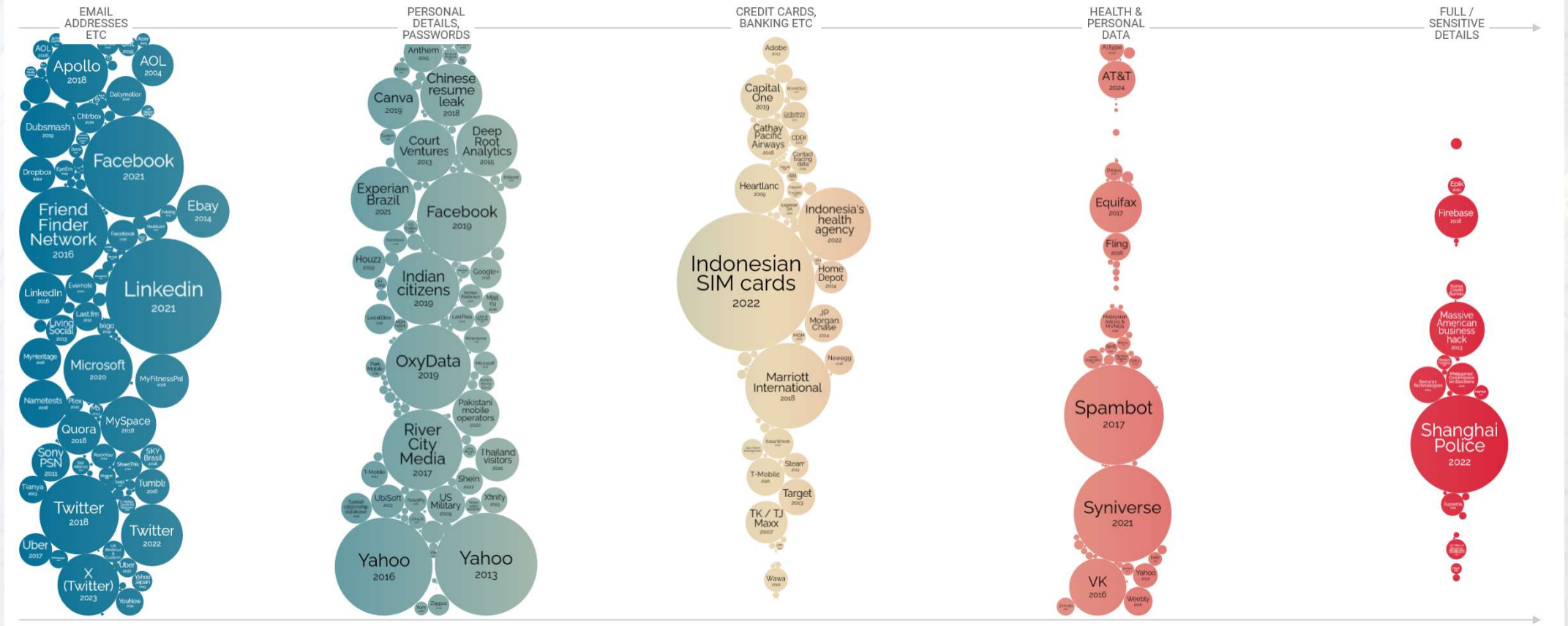


信息安全现状





Data Breaches by data sensitivity





2023年数据泄露风险概况

- 2023年，全网监测并分析验证有效的数据泄露事件超过19500起，涉及金融、物流、航旅、电商、汽车等20余个行业；
- 金融行业超过物流行业，成为2023年公民个人信息泄露事件数量最多的行业；2023年航旅行业公民个人信息泄露事件数量也出现大幅增长，在公民个人信息泄露的行业分布中首次排名前三；
- 从数据泄露渠道来看，主要集中在更加隐蔽和便利的匿名群聊、暗网渠道；值得一提的是，公民个人信息泄露事件的数据交易时间中，夜间交易的超过50%，在非工作日交易的超过30%。

2023年数据泄露事件数量Top5行业



2023年数据泄露主要原因





信息安全的定义

- 信息安全指信息系统（包括硬件、软件、数据、人、物理环境及其基础设施）受到保护，不受偶然的或者恶意的原因而遭到破坏、更改、泄露，系统连续可靠正常地运行，信息服务不中断，最终实现业务连续性。

安全目标：C.I.A.

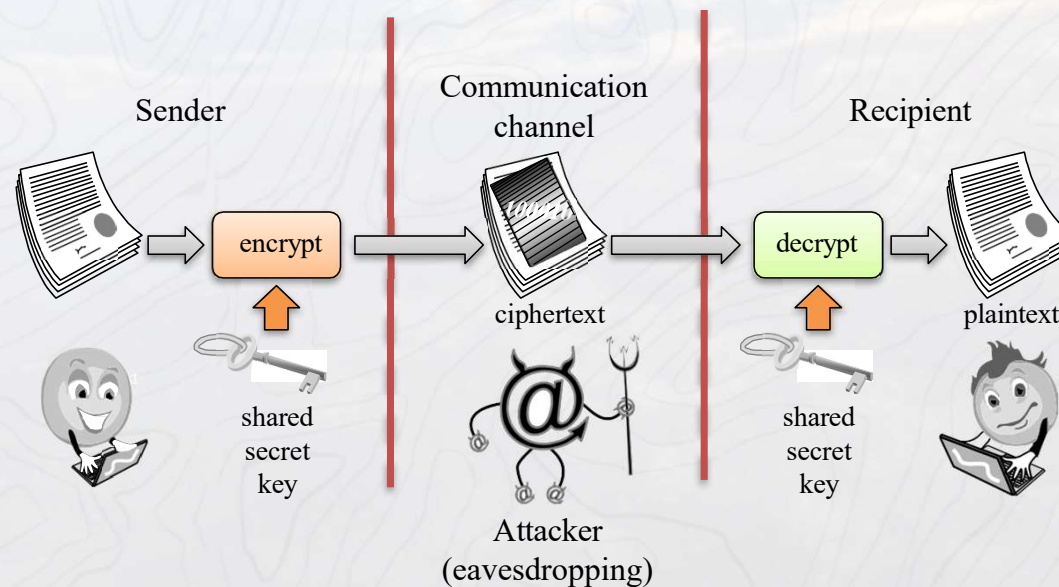


机密性

- 机密性是为了避免未经授权的信息披露。
 - Confidentiality involves the protection of data, providing access for those who are allowed to see it while disallowing others from learning anything about its content.

机密性工具

- Encryption (加密): 使用加密密钥进行信息转换, 以便只能使用解密密钥 (在某些情况下可能与加密密钥相同) 读取转换后的信息。



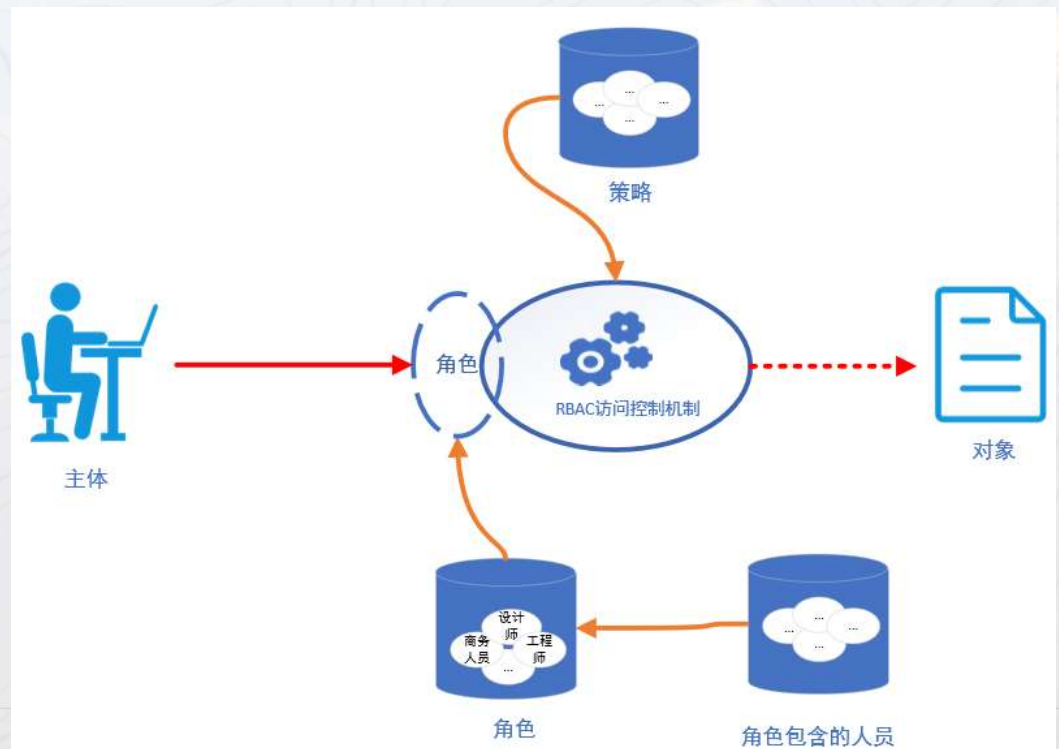


机密性

- 机密性是为了避免未经授权的信息披露。
 - Confidentiality involves the protection of data, providing access for those who are allowed to see it while disallowing others from learning anything about its content.

机密性工具

- Access control (访问控制)：保护信息资源不被非授权使用或控制。
 - 可能需要通过身份（例如，一个人的姓名或计算机的序列号）或一个人所扮演的角色（例如，经理或计算机安全专家）来确定此需求。



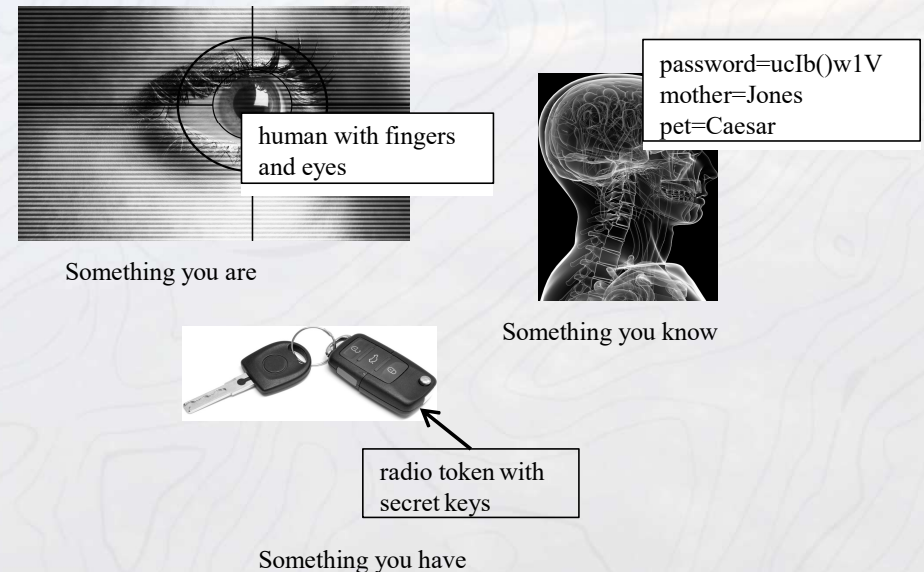


机密性

- 机密性是为了避免未经授权的信息披露。
 - Confidentiality involves the protection of data, providing access for those who are allowed to see it while disallowing others from learning anything about its content.

机密性工具

- Authentication (验证)：确定某人的身份或角色。可以通过许多不同的方法来完成此确定，通常是基于以下方法的组合
 - something the person has (like a smart card or a radio key fob storing secret keys),
 - something the person knows (like a password),
 - something the person is (like a human with a fingerprint).





机密性

- 机密性是为了避免未经授权的信息披露。
 - Confidentiality involves the protection of data, providing access for those who are allowed to see it while disallowing others from learning anything about its content.

机密性工具

- Authorization（授权）：根据访问控制策略确定是否允许个人或系统访问资源。
 - 防止攻击者诱骗系统让他可以访问受保护的资源。
- Physical security（物理安全）：建立物理障碍以限制对受保护的计算资源的访问。
 - Such barriers include locks on cabinets and doors, the placement of computers in windowless rooms, the use of sound dampening materials, and even the construction of buildings or rooms with walls incorporating copper meshes (called Faraday cages) so that electromagnetic signals cannot enter or exit the enclosure.



完整性

- Integrity（完整性）：保证数据不被非授权地修改、删除或代替，或能够检测这些非授权改变。

完整性工具

- Backups（备份）：定期归档数据。
- Checksums（校验和）：将文件内容映射为数值的函数。校验和函数取决于文件的全部内容，并且其设计方式是，即使对输入文件进行很小的更改（例如，修改1-bit）也很可能导致不同的输出值
- Data correcting codes（数据校正代码）：一种存储数据的方法，可以轻松检测并自动校正微小的变化



可用性

- Availability（可用性）：保证授权用户能够对所需的信息或资源的访问。

可用性工具

- Physical protections（物理保护）：基础设施旨在解决即使在物理挑战中也能保持信息的可用性
- Computational redundancies（计算冗余）：在发生故障时充当后备功能的计算机和存储设备



其他安全概念：A.A.A.





保障性

- 保障性是指在计算机系统中如何提供信任管理。
- 信任管理取决于：
 - 策略，指定人或系统对自己和他人的行为期望。
[例] 在线音乐系统的设计者可能会指定一些政策，说明用户如何访问和复制歌曲。
[例] 公司网络管理员可能会制定防火墙策略，说明员工可以进行的网络活动。
 - 许可，描述与人或系统交互的代理所允许的行为。
[例] 在线音乐商店可为已购买某些歌曲的用户提供有限访问和复制权限。
[例] 防火墙允许员工访问某些IP地址。
 - 保护，描述了用于实施权限和策略的机制。
[例] 在线音乐商店会建立保护措施，防止人们未经授权访问和复制其歌曲。
[例] 防火墙会检查数据流，避免未经授权访问和数据泄漏。



真实性

- 真实性是确定人员或系统发布的声明，策略和权限是真实的。

真实性工具

- Digital signatures（数字签名）是只有信息的发送者才能产生的别人无法伪造的一段数字串，这段数字串同时也是对信息的发送者发送信息真实性的一个有效证明。它是一种类似写在纸上的普通的物理签名、使用密码学领域的技术来实现、用于鉴别数字信息的方法。





匿名性

- 某些记录或交易不属于任何个人的财产。

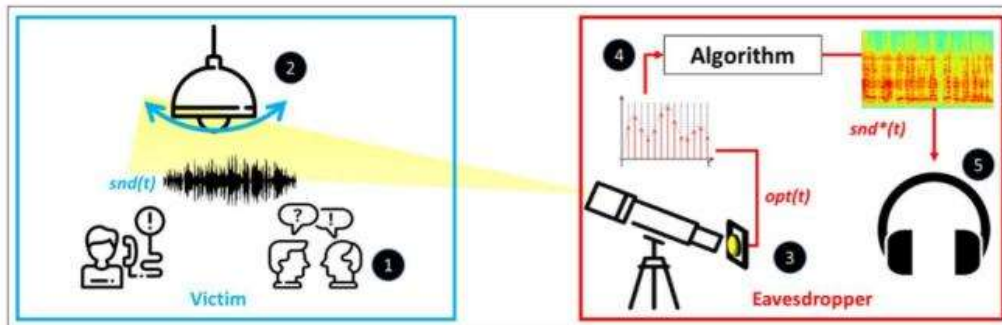
匿名性工具

- Aggregation（聚合）：来自许多个人的数据的合并，这样披露的总和或平均值就不会与任何个人联系在一起。
- Mixing（混合）：交易，信息或通信的交织以无法追踪到任何个人的方式。
- Proxies（代理）：提供匿名服务的受信任的代理。
- Pseudonyms（假名）：填充通信和交易中的真实身份的虚构身份，只有可信实体才能知道。



常见的安全威胁与攻击方式

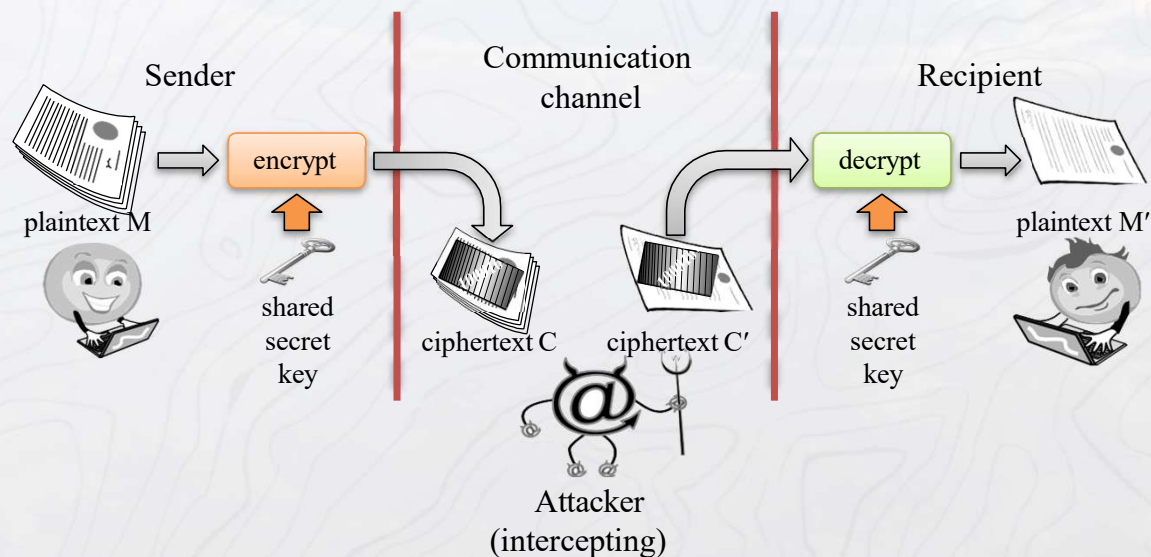
- Eavesdropping (窃听) : 拦截在通信通道上传输给他人的信息。



常见的安全威胁与攻击方式

- Eavesdropping (窃听) : 拦截在通信通道上传输给他人的信息。
- Alteration (or Tampering, 改造) : 未经授权擅自修改信息。

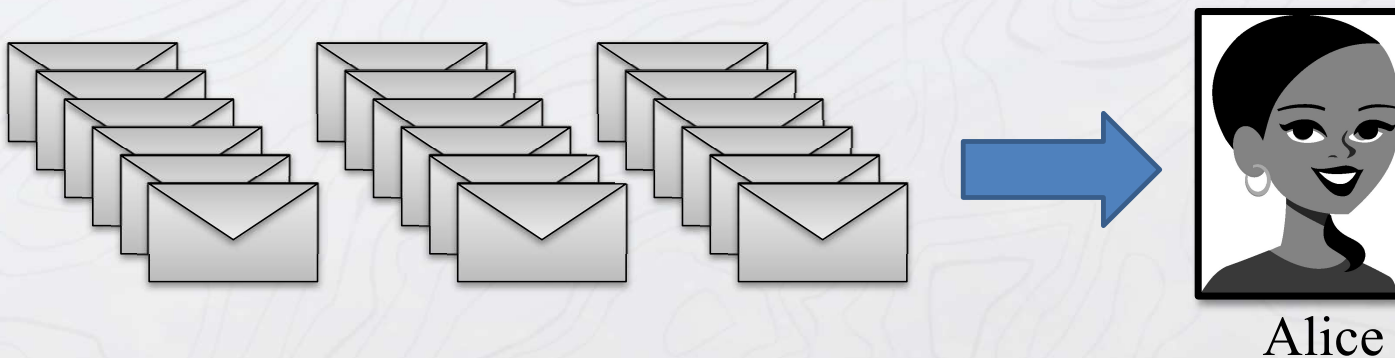
[例] 中间人攻击: 攻击者作为中间人, 劫持通信双方会话并操纵通信过程, 而通信双方并不知情, 从而达到窃取信息或冒充访问的目的。





常见的安全威胁与攻击方式

- Eavesdropping（窃听）：拦截在通信通道上传输给他人的信息。
- Alteration（or Tampering, 改造）：未经授权擅自修改信息。
[例] 中间人攻击：攻击者作为中间人，劫持通信双方会话并操纵通信过程，而通信双方并不知情，从而达到窃取信息或冒充访问的目的。
- Denial-of-service（拒绝服务）：数据服务或信息访问的中断或降级。
[例] 垃圾邮件：大量垃圾邮件填满服务器的队列，导致正常邮件无法传送。





常见的安全威胁与攻击方式

- Eavesdropping（窃听）：拦截在通信通道上传输给他人的信息。
- Alteration（or Tampering, 改造）：未经授权擅自修改信息。
[例] 中间人攻击：攻击者作为中间人，劫持通信双方会话并操纵通信过程，而通信双方并不知情，从而达到窃取信息或冒充访问的目的。
- Denial-of-service（拒绝服务）：数据服务或信息访问的中断或降级。
[例] 垃圾邮件：大量垃圾邮件填满服务器的队列，导致正常邮件无法传送。
- Masquerading（or Spoofing, 伪装）：伪造的信息据称是来自（实际上并非）作者的人。



常见的安全威胁与攻击方式

- Eavesdropping（窃听）：拦截在通信通道上传输给他人的信息。
- Alteration（or Tampering, 改造）：未经授权擅自修改信息。
[例] 中间人攻击：攻击者作为中间人，劫持通信双方会话并操纵通信过程，而通信双方并不知情，从而达到窃取信息或冒充访问的目的。
- Denial-of-service（拒绝服务）：数据服务或信息访问的中断或降级。
[例] 垃圾邮件：大量垃圾邮件填满服务器的队列，导致正常邮件无法传送。
- Masquerading（or Spoofing, 伪装）：伪造的信息据称是来自（实际上并非）作者的人。
- Correlation and traceback（相关性和追溯）：集成多个数据源和信息流，以确定特定数据流或一条信息的源。



常见的安全威胁与攻击方式





十大安全原则





木桶原则

- 强调对信息均衡、全面地进行保护
 - “木桶的最大容积取决于最短的一块木板”，攻击者必然在系统中最薄弱的地方进行攻击。因此，充分、全面、完整地对系统的安全漏洞和安全威胁进行分析、评估和检测（包括模拟攻击），是设计信息安全系统的必要前提条件。安全机制和安全服务设计的首要目的是防止最常用的攻击手段；根本目标是提高整个系统的“安全最低点”的安全性能。

整体性原则

- 安全防护、监测和应急恢复
 - 没有百分之百的信息安全，因此要求系统被攻击、破坏事件的情况下，必须尽可能快地恢复服务，减少损失。所以信息安全系统应该包括三种机制：安全防护机制；安全监测机制；安全恢复机制。



安全性评价

- 强调实用安全性与用户需求和应用环境紧密相关
 - 评价系统是否安全，没有绝对的评判标准和衡量指标，只能决定于系统的用户需求和具体的应用环境

等级性原则

- 安全层次和安全级别
 - 良好的信息安全系统必然是分为不同级别的，包括：对信息保密程度分级（绝密、机密、秘密、普密）；对用户操作权限分级（面向个人及面向群组）。从而针对不同级别的安全对象，提供全面的、可选的安全算法和安全体制，以满足不同层次的各种实际需求。



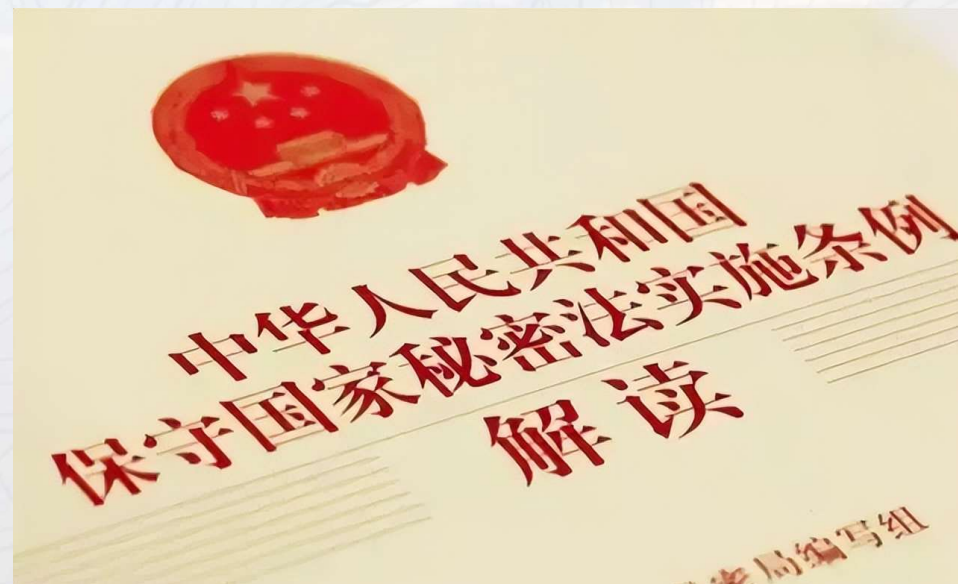
国家秘密标志

书面形式的密件，其国家秘密的标识为“★”，“★”前标密级，“★”后标保密期限。
非书面形式的密件，应当以能够明显识别的方式在密件上标明密级和保密期限，
凡有包装(套、盒、袋等)的密件，还应当以恰当方式在密件的包装上标明。

完整的国家秘密标志内容

“密级★保密期限”；“密级★解密时间”；
“密级★解密条件”

- “绝密”是非常重要的国家秘密，泄露会使国家的安全和利益遭受特别严重的损害；
- “机密”是重要的国家秘密，泄露会使国家的安全和利益遭受严重的损害；
- “秘密”是一般的国家秘密，泄露会使国家的安全和利益遭受损害。





动态化原则

- 整个系统内尽可能引入更多的可变因素，并具有良好的扩展性
 - 被保护的信息的生存期越短、可变因素越多，系统的安全性能就越高。安全系统要针对系统升级保留一定的冗余度，整个系统内尽可能引入更多的可变因素。

设计为本原则

- 安全系统的设计应与具体业务场景相结合
 - 避免因考虑不周，出了问题之后拆东墙补西墙，不仅造成经济上的巨大损失，而且也会对国家、集体和个人造成无法挽回的损失。由于安全问题是— 一个相当复杂的问题，因此必须群策群力搞好设计，才能保证安全性。



自主可控性原则

- 安全问题关系着一个国家的主权和安全，所以安全系统不可能依赖于国外，必须解决信息安全的自主权和自控权问题

国密算法

中国密码算法是由中国政府组织设计和推广的一套密码算法标准。这些算法广泛应用于中国的信息安全领域，包括加密、数字签名、身份认证等方面。

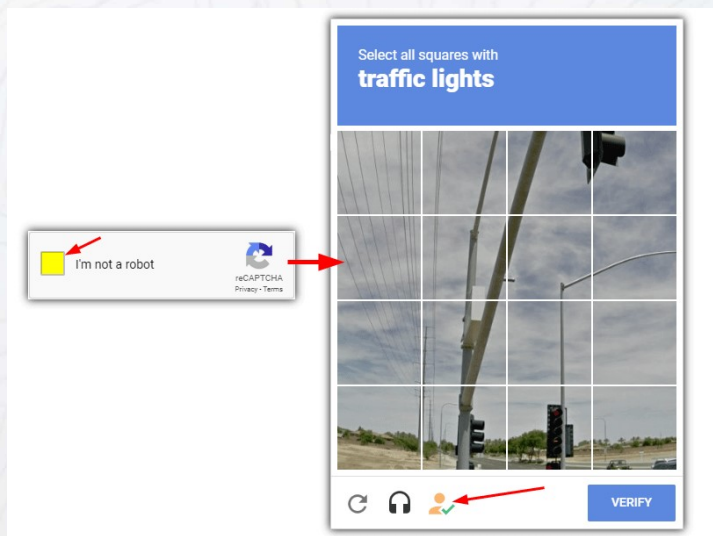
国密算法主要包括对称加密算法、非对称加密算法和哈希算法。这些算法在设计上充分考虑了安全性、效率和国内法律法规的要求。

- SM1算法：SM1是一种分组密码算法，适用于对称加密。它采用了非线性的S盒和置换运算，具有良好的安全性和高效率。
- SM2算法：SM2是一种非对称加密算法，适用于数字签名、密钥交换等场景。它基于椭圆曲线密码学，具有与RSA算法相当的安全性，但更加高效。
- SM3算法：SM3是一种哈希算法，适用于消息摘要和数字签名等场景。它采用了类似SHA-256的结构，但具有更好的性能和安全性。



有效性与实用性

- 不能影响系统的正常运行和合法操作
 - 如何在确保安全性的基础上，把安全处理的运算量减小或分摊，减少用户记忆、存储工作和安全服务器的存储量、计算量，应该是一个网络系统信息安全设计者主要解决的问题。





reCAPTCHA (Completely Automated Public Turing Test To Tell Computers and Humans Apart)

- 2007年，卡内基梅隆大学教授路易斯·冯·安推出的验证码系统，已被谷歌收购
- 针对问题：纸质材料电子化
- 系统设计：验证码由两部分组成
 - 第一部分是自动生成并且经过变形处理的文字，用来检验你是不是真人
 - 第二部分是从无法识别的文本中截取出来的词



reCAPTCHA (Completely Automated Public Turing Test To Tell Computers and Humans Apart)

- 2007年，卡内基梅隆大学教授路易斯·冯·安推出的验证码系统，已被谷歌收购
- 针对问题：纸质材料电子化
- 系统设计：验证码由两部分组成
 - 第一部分是自动生成并且经过变形处理的文字，用来检验你是不是真人
 - 第二部分是从无法识别的文本中截取出来的词
- 谷歌收购后加入Google街景中难以识别的门牌和路牌等图像数据。
- 除了标注门牌路牌，让用户帮忙给数据库分类也是常见的形式之一。





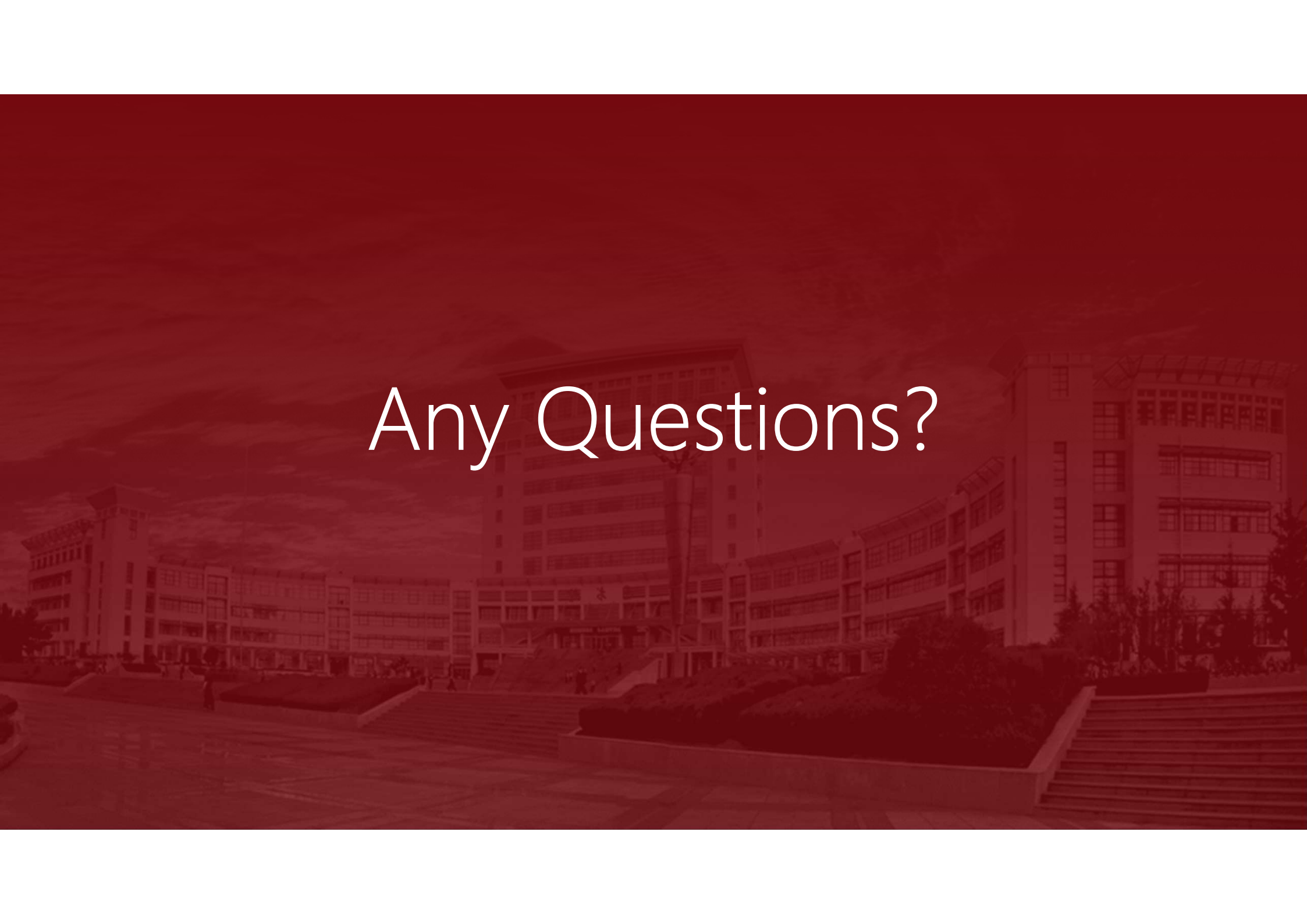
权限分割、互相制约、最小化原则

- 权限分割

有必要对系统超级用户的权限加以限制，实现权限最小化原则。管理权限交叉，有几个管理用户来动态地控制系统的管理，实现互相制约。而对于非管理用户，即普通用户，则实现权限最小原则，不允许其进行非授权以外的操作。

有的放矢、各取所需原则

- 在考虑安全问题解决方案时必须考虑性能价格的平衡，而且不同的网络系统所要求的安全侧重点各不相同。必须有的放矢，具体问题具体分析，把有限的经费花在刀刃上。

A photograph of a university campus with several large, multi-story academic buildings and a central courtyard with stairs and landscaping. The image is overlaid with a semi-transparent dark red filter.

Any Questions?

密码学

為天下儲人材 為國家圖富強

—— 学无止境 气有浩然 ——



密码学

- Is
 - 强大的工具
 - 许多安全机制的基础
- Is not
 - 所有安全问题的解决方案
 - Reliable unless implemented properly
 - Reliable unless used properly
 - Something you should try to invent yourself unless
 - you spend a lot of time becoming an expert
 - you subject your design to outside review



柯克霍夫(Auguste Kerckhoffs)原则

- 密码系统应该是计算安全的；密钥由通信双方事先约定好，并根据一定协议进行更换；密码系统应易于使用；密码系统应该精确而有效；除了密钥，密码系统的所有细节都为对手所知。

A cryptosystem should be secure even if everything about the system, except the key, is public knowledge.



Auguste Kerckhoffs
19世纪 荷兰密码学家

- 1.即使非数学上不可破解，系统也应在实质（实用）程度上无法破解。
- 2.系统内不应含任何机密物，即使落入敌人手中也不会造成困扰。
- 3.密匙必须易于沟通和记忆，而不须写下；且双方可以容易的改变密匙。
- 4.系统应可以用于电讯。
- 5.系统应可以携带，不应需要两个人或以上才能使用（应只要一个人就能使用）。
- 6.系统应容易使用，不致让用户的脑力过分操劳，也无需记得长串的规则。



威胁模型

- 假设攻击者知道密码系统
- 攻击者不知道系统中的随机数
 - 系统运行时生成，而非预设

示例：网络交易



假设攻击者可以控制网络

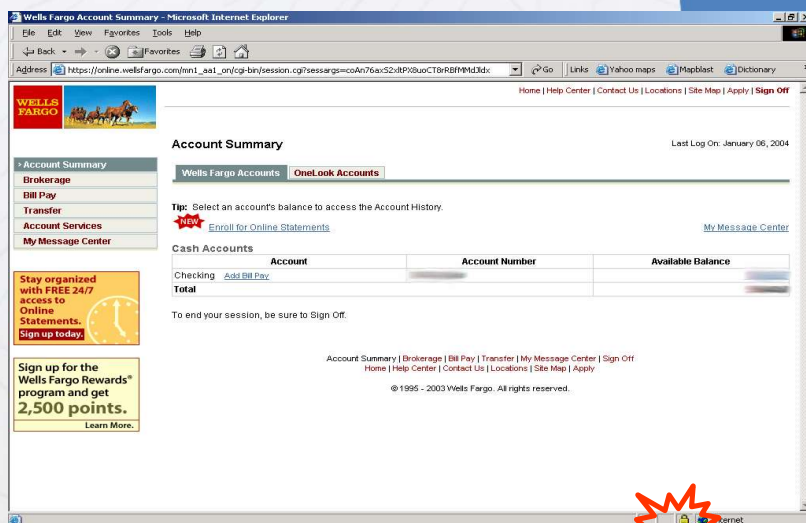
- 后续课程学习
- 攻击者可以拦截数据包，篡改或抑制数据包，并注入任意数据包



目标1: 安全通信

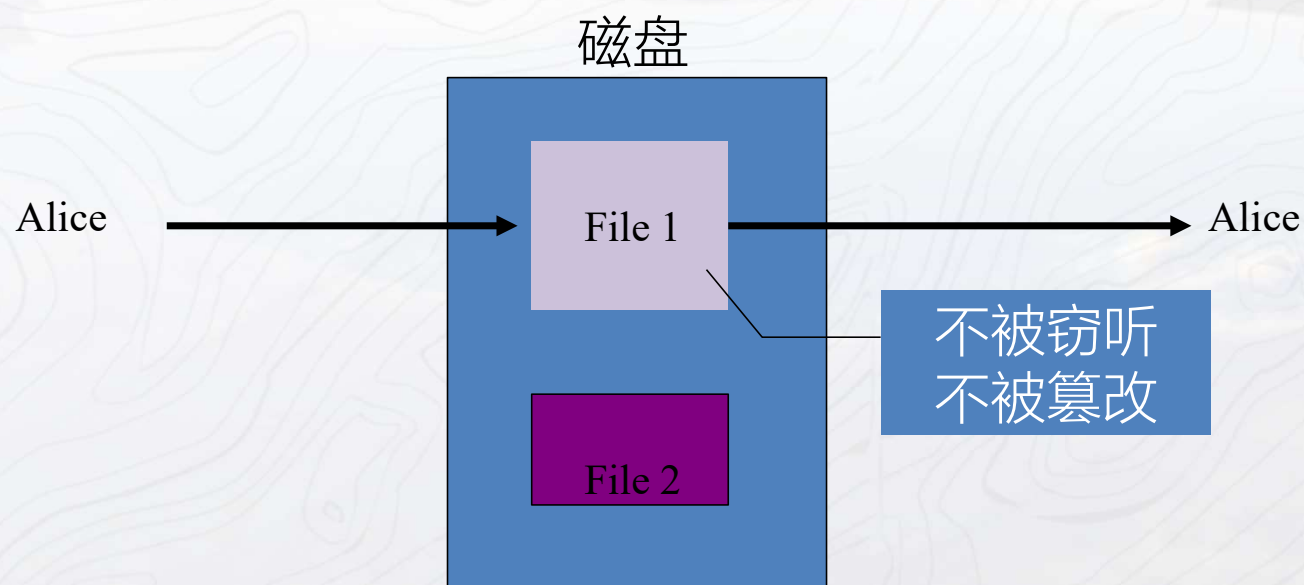
Step 1: 交换密钥

Step 2: 加密数据





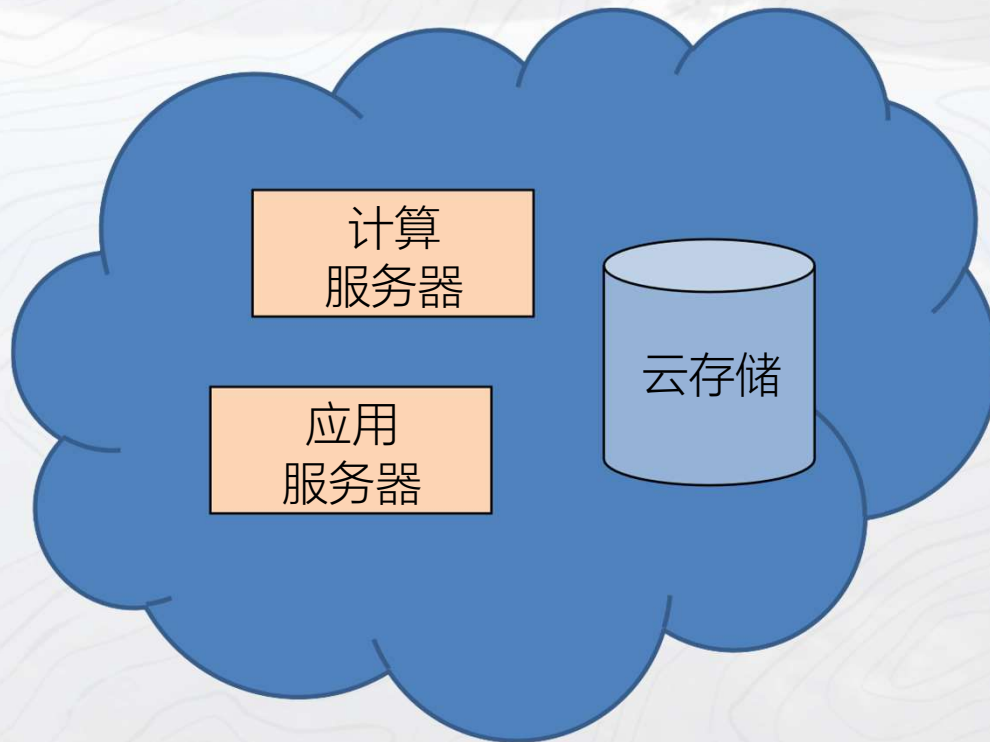
目标2：受保护的文件



类似于安全通信：
可以看作Alice给未来的Alice发送信息



目标3：安全的云计算？





密码学概念

- 密码：简短的字符序列，用于通过他们知道的秘密对某人进行身份验证
- 强安全密码：

- UPPER/lower case characters
- Special characters
- Numbers

Group	Example
Lowercase letters	a, b, c, ...
Uppercase letters	A, B, C, ...
Numerals	0, 1, 2, 3, 4, 5, 6, 7, 8, 9
Non-alphanumeric (symbols)	() ` ~ ! @ # \$ % ^ & * - + = \ { } [] : ; " ' < > , . ? /
Unicode characters	€, Γ, f, and λ

- 示例：
 - The 10 Most Common Passwords in 2021:
123456, 123456789, qwerty, password, 12345, qwerty123, 1q2w3e, 12345678, 111111, 1234567890
 - ppnn13%dkstFeb.1st (娉娉袅袅十三余，豆蔻梢头二月初)
 - 随机密码生成器



密码学概念

- 密码复杂度:

A fixed 6 symbols password:

Numbers $10^6 = 1,000,000$

UPPER or lower case characters $26^6 = 308,915,776$

UPPER and lower case characters $52^6 = 19,770,609,664$

32 special characters (&, %, \$, £, “, |, ^, §, etc.) $32^6 = 1,073,741,824$

Total 94 practical symbols available

$94^6 = 689,869,781,056$

Odd characters make passwords safer



密码学概念

- 密码复杂度:

26 UPPER/lower case characters = 52 characters

10 numbers

32 special characters

=> 94 characters available

5 characters: $94^5 = 7,339,040,224$

6 characters: $94^6 = 689,869,781,056$

7 characters: $94^7 = 64,847,759,419,264$

8 characters: $94^8 = 6,095,689,385,410,816$

9 characters: $94^9 = 572,994,802,228,616,704$

使用破解的服务器集群，每秒可以尝试3500亿次，这个速度破解6位密码只需要4.08秒，7位密码只需6.47分钟，8位密码需要10.24小时，9位密码需要40.53天，10位密码就需要10.55年了。

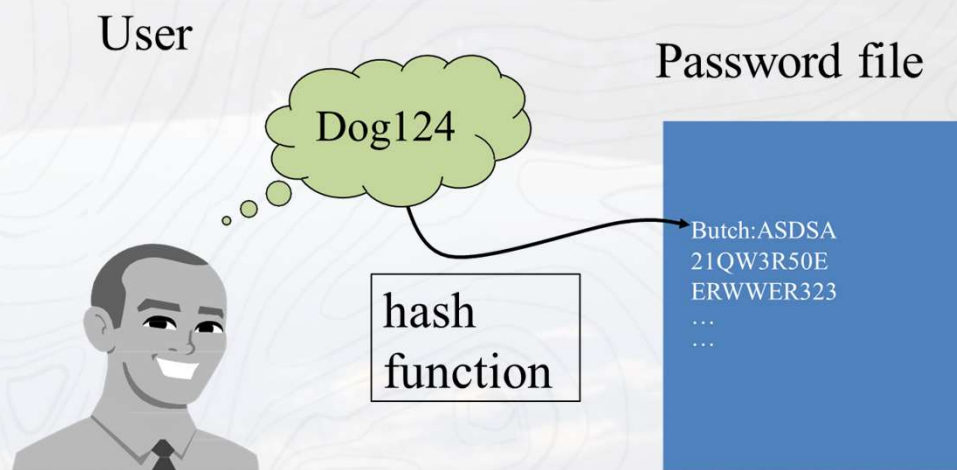
Longer passwords are better



密码如何存储？

服务器端：

- 直接存储用户密码的明文或者将密码加密存储。
- 将明文密码做单向哈希后存储。
- 将明文密码混入“随机因素”，然后进行单向哈希后存储。



用户端：

- 设计有规律的密码记忆
- 写在密码本或存在计算机文件中（明文or加密）
- 借助随机密码生成&存储器（例：浏览器保存密码）
- 不用密码登录，而是短信验证码、临时口令等



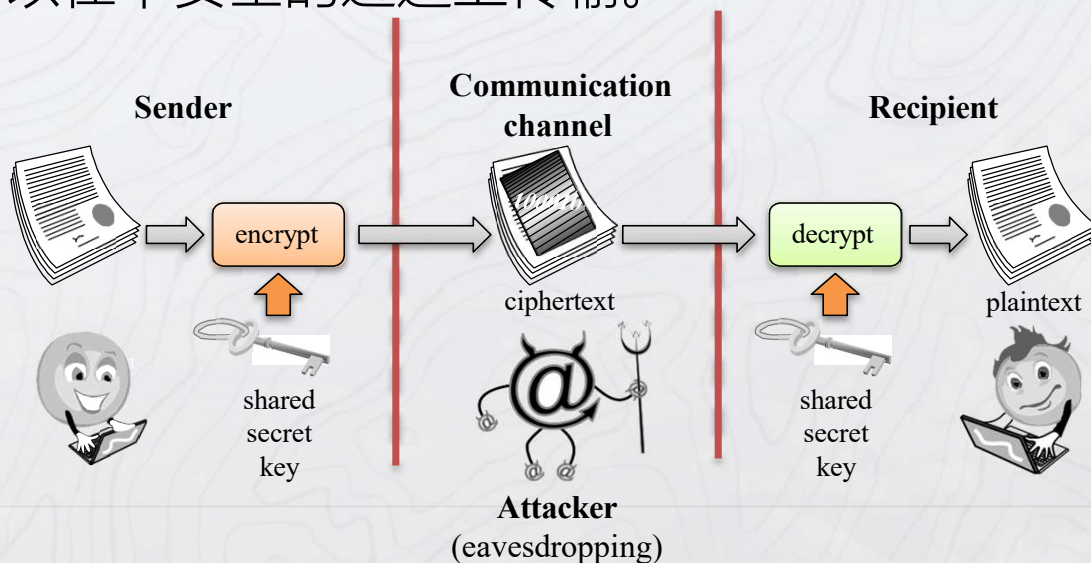
密码学概念

- Encryption（加密）：一种允许Alice和Bob在不安全信道建立机密通信的方法。
- 消息M称为明文plaintext。
- Alice将使用加密算法E将文本M转换为加密形式，该算法输出M的密文为C。

$$C = E_k(M)$$

$$M = D_k(C)$$

- 选择加密和解密算法，以使除Alice和Bob之外的其他人无法从密文C推断明文M。因此，密文C可以在不安全的通道上传输。





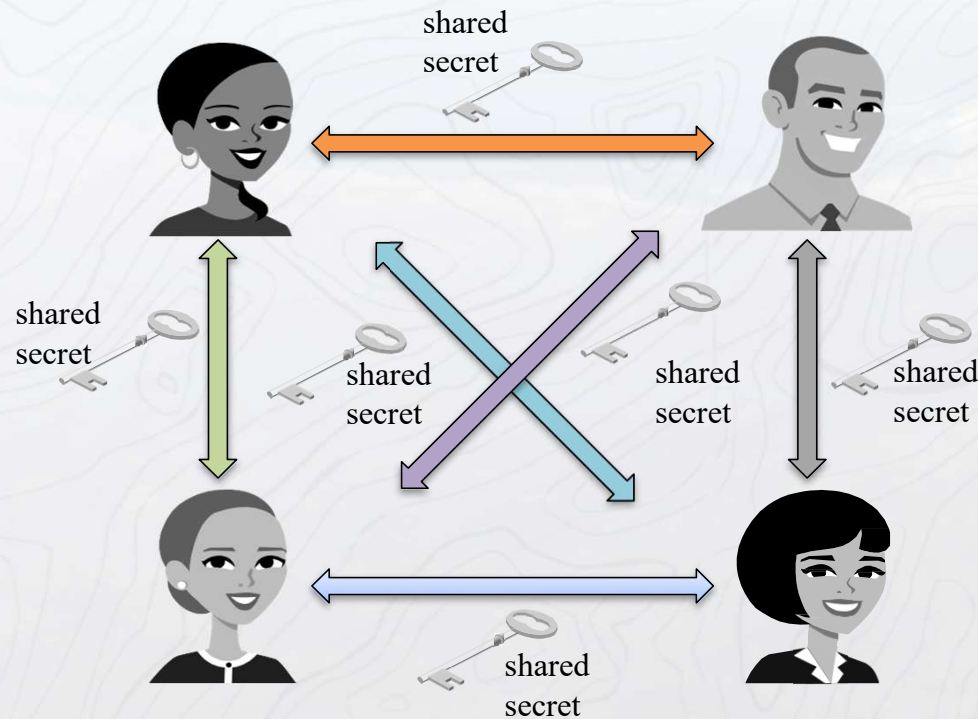
密码系统 Cryptosystem

- 是一个五元集合 $CS = \{M, C, K, E, D\}$
 - 明文消息空间 $M = \{m\}$, 表示明文消息的集合;
 - 密文消息空间 $C = \{c\}$, 表示密文消息的集合;
 - 密钥空间 $K = \{k\}$, 表示密钥的集合;
 - 加密变换 E , 表示一个确定的映射;
 - 解密变换 D , 表示一个确定的映射;



对称密码系统(Symmetric Cryptosystems)

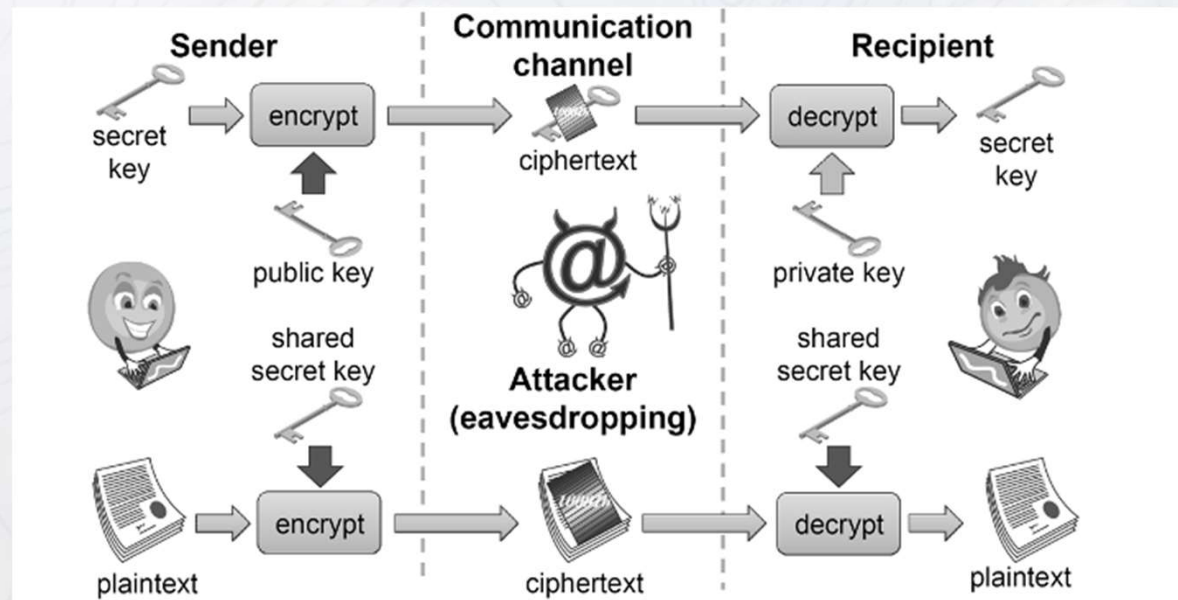
- Alice和Bob共享一个密钥，该密钥用于加密和解密。
- 要求每一对通信方共享一个（单独的）密匙。





公钥密码学Public-Key Cryptography

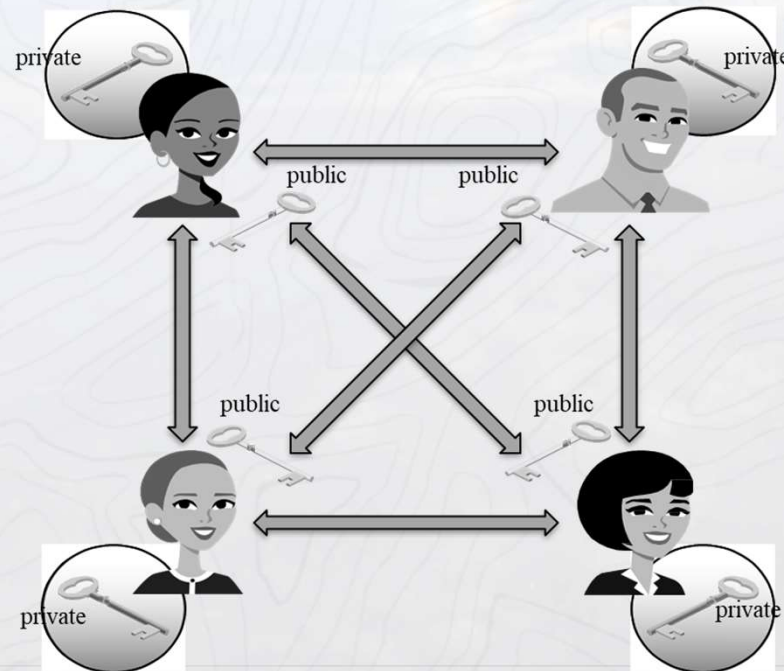
- Bob有两个密钥：Bob保存秘密的私钥SK并广播其公开密钥PK。
 - Alice要向Bob发送加密信息，只需获得他的公开密钥 PK，用它对信息 M 进行加密，然后将结果 $C = EPK(M)$ 发送给Bob。然后，Bob使用他的密钥 SK 将信息解密为 $M = DSK(C)$ 。
- 单独的密钥用于加密和解密。





公钥密码学Public-Key Cryptography

- Bob有两个密钥：Bob保存秘密的私钥SK并广播其公开密钥PK。
 - Alice要向Bob发送加密信息，只需获得他的公开密钥 PK，用它对信息 M 进行加密，然后将结果 $C = EPK(M)$ 发送给Bob。然后，Bob使用他的私钥 SK 将信息解密为 $M = DSK(C)$ 。
- 单独的密钥用于加密和解密。
- 每个接收者只需一个密钥。





数字签名

- 公钥加密提供了一种进行数字签名的方法
 - 要签署一条信息 M , Alice 只需用自己的私人密钥 SA 对其加密, 即可创建 $C = E_{SA}(M)$ 。
 - 任何人都可以使用 Alice 的公开密钥解密该信息, 即 $M' = D_{PA}(C)$, 并将其与信息 M 进行比较。



数字签名

- 公钥加密提供了一种进行数字签名的方法
 - 要签署一条信息 M , Alice 只需用自己的私人密钥 $C = E_{SA}(M)$ 。
 - 任何人都可以使用 Alice 的公开密钥解密该信息, 与信息 M 进行比较。

数字证书

- 证书颁发机构(Certificate authority, i.e., CA) 以数字形式在身份和该身份的公钥之间进行绑定。

证书查看器: www.sdu.edu.cn

常规(G) 详细信息(D)

颁发给

公用名(CN)	www.sdu.edu.cn
组织(O)	山东大学
组织单位(OU)	<不是证书的一部分>

颁发者

公用名(CN)	DigiCert Basic RSA CN CA G2
组织(O)	DigiCert Inc
组织单位(OU)	<不是证书的一部分>

有效期

颁发日期	2023年12月18日星期一 08:00:00
到期日期	2025年1月14日星期二 07:59:59

SHA-256 指纹

证书	ef9ee3c149ed779f76305c051dc5b328d6437b895598005f9b618410b2d2e5f1
公钥	f6bd8d2f3784eb0c5d5ab6538b8c6d12b55b1530d00d0c166c7979db58cadf92

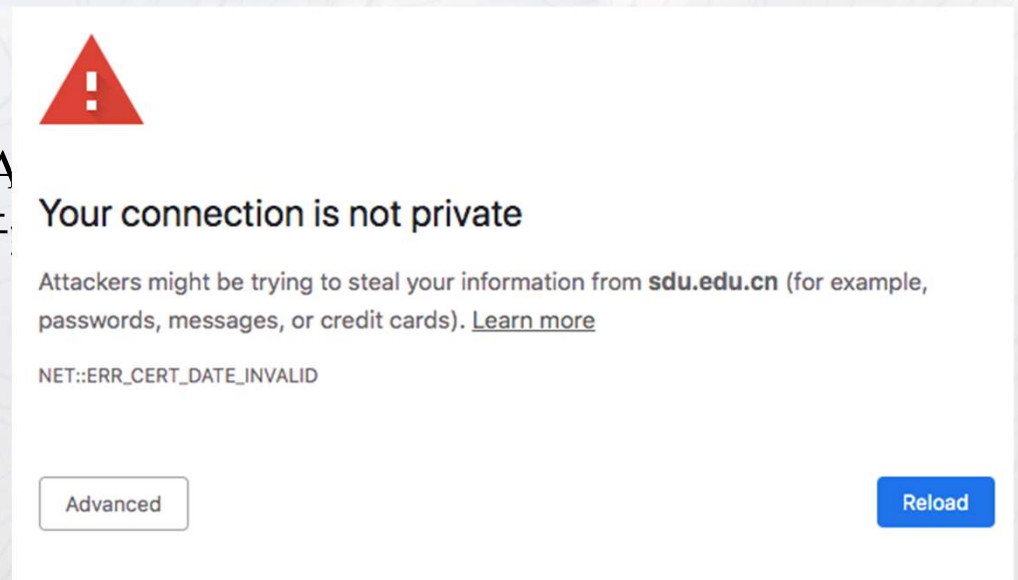


数字签名

- 公钥加密提供了一种进行数字签名的方法
 - To sign a message, M , Alice just encrypts it with her private key, SA , creating $C = E_{SA}(M)$.
 - Anyone can decrypt this message using Alice's public key, as $M' = D_{PA}(C)$, and compare that to the message M .

数字证书

- 证书颁发机构(Certificate authority, i.e., CA)以数字形式在身份和该身份的公钥之间进行绑定





密码学哈希函数Cryptographic Hash Functions

- 消息M的校验和，即：
 - **One-way** (单向性) : it should be easy to compute $Y=H(M)$, but hard to find M given only Y
 - **Collision-resistant** (防碰撞) : it should be hard to find two messages, M and N, such that $H(M)=H(N)$.
- 例如: SHA-1, SHA-256.

消息验证码Message Authentication Codes

- 如果Alice和Bob共享密钥，则允许他们验证数据完整性。
- 给定消息M， Alice计算 $H(K \parallel M)$ 并将M和此哈希发送给Bob。



消息验证码Message Authentication Codes

- 如果Alice和Bob共享密钥，则允许他们验证数据完整性。
- 给定消息M，Alice计算 $H(K \parallel M)$ 并将M和此哈希发送给Bob。

